

VirtuEx 시스템 감사 보고서 (22차)

VirtuEx System Audit Report (22nd)

- 감사일: 2026-03-23
- 감사 범위: API 보안, 입력 검증, 에러 처리, 인증/인가, DB 무결성, 서비스 간 통신, 로깅/모니터링, 프론트엔드 보안, HTTP 보안 헤더, WebSocket 보안, IDOR, 감사 로깅
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭 + 22차 강화 기준 적용
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 21차 대비 수정 현황을 검증하고, 수정 과정에서 도입된 신규 이슈를 포함합니다

이전 감사 대비 수정 현황 (21차 → 22차)

이전 이슈	상태	비고
[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장	수정됨	httpOnly + Secure + SameSite=Strict 쿠키로 전환 완료. auth.ts에서 partialize로 accessToken 제외, jwt.strategy.ts에서 쿠키 우선 추출, api.ts에서 withCredentials: true 사용
[SEC-H-01] CORS allowedHeaders에 x-user-id 포함	수정됨	main.ts:109에서 allowedHeaders를 ['Content-Type', 'Authorization', 'Accept']로 제한. 내부 헤더(x-user-id, x-internal-token) 제거 완료
[AUTH-H-01] AI 엔드포인트 인증/Rate Limit 미적용	수정됨	ai-proxy.controller.ts에 컨트롤러 레벨 @UseGuards(JwtAuthGuard) + @Throttle({ default: { ttl: 60000, limit: 10 } }) 적용 완료
[AUD-H-01] 관리자 민감 작업 감사 로그 미기록	수정됨	admin-proxy.controller.ts에 [ADMIN_AUDIT] 구조화 로그 추가 (adminId, action, targetId). announcement-proxy.controller.ts에도 동일 패턴 적용
[VAL-M-01] PlaceOrderDto quantity/price 형식 검증 부재	수정됨	@Matches(/^\\d+(\\.\\d+)?\$/) + @MaxLength(50) 적용 완료 (quantity, price, triggerPrice 모두)
[HDR-M-01] Permissions-Policy 헤더 미설정	수정됨	next.config.ts:47에 Permissions-Policy 헤더 추가, main.ts:61에 미들웨어로 동일 헤더 설정
[CSP-M-02] CSP connect-src localhost 와일드카드 허용	수정됨	next.config.ts:11-15에서 isDev 조건으로 프로덕션 빌드에서 http://localhost:* 제거
[VAL-M-02] 주문 수량 프론트엔드 소수점 자릿수 미제한	미수정	OrderForm.tsx:304에서 직접 입력 시 여전히 소수점 제한 없음
[ERR-M-01] 주문 프로세스 거래 알림 실패 시 내부 에러 메시지 로깅	미수정	order-proxy.controller.ts:62에서 e.message 로그 노출 유지

[ERR-M-02] 관리자 감사 trades any 타입 사용	미수정	order-proxy.controller.ts:164-176, portfolio-proxy.controller.ts 전반에서 Record<string, any>, (t: any) 등 유지
[ERR-L-01] 프론트엔드 catch 블록 에러 무시 패턴	미수정	portfolio/page.tsx:99,113에서 catch { // Error handled by query client } 패턴 유지
[CSP-M-01] CSP unsafe-inline + strict-dynamic 공존	미수정	next.config.ts:9에서 프로덕션 CSP 동일 설정 유지
[AUTH-M-01] 호가창 엔드포인트 인증 불필요 노출	미수정	GET /api/orders/book/:symbol에 인증 가드 없음
[AUTH-L-01] 공개 포트폴리오 API 보유 자산 상세 노출	미수정	절대 수량 마스킹 미적용
[SVC-M-01] 서비스 간 HTTP 통신 HTTPS 미적용	미수정	proxy.service.ts:71-77에서 http:// 유지
[AUD-M-01] 비밀번호 재설정 감사 로깅 불충분	미수정	auth.service.ts:704에서 성공 시 logger.log만 기록, 실패 시 별도 로그 없음
[FE-M-01] RichEditor 이미지 업로드 서버 실패 시 Base64 폴백	미수정	RichEditor.tsx:144-147에서 Base64 data URL 폴백 유지
[FE-M-02] 주문 폼 displayCurrentPrice 기반 최대 수량 계산 편차	미수정	OrderForm.tsx:321에서 portfolio.cashBalance / displayCurrentPrice 계산 유지
[MISC-L-01] 공지사항 Gateway AdminRolesGuard 미적용	미수정	AnnouncementProxyController에 AdminRolesGuard 여전히 없음. 단, 감사 로고는 추가됨
[VAL-L-01] auth-proxy 컨트롤러 body 타입 unknown 전달	미수정	auth-proxy.controller.ts에서 @Body() body: unknown 패턴 유지

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안	0	1	0	0	1
B. 입력 검증	0	0	1	1	2
C. 에러 처리/정보 노출	0	0	2	1	3

D. XSS/CSP 방어	0	0	1	0	1
E. 인가/권한 검증	0	0	1	2	3
F. 서비스 간 통신	0	0	1	0	1
G. 감사 로깅	0	0	1	0	1
H. 기타	0	0	2	0	2
합계	0	1	9	4	14

A. 인증/토큰 보안 — 1건

[SEC-H-02] API Gateway 로그아웃 시 access_token 쿠키 미삭제 (High, 22차 신규)

- **현상:** SEC-C-01 수정으로 액세스 토큰이 httpOnly 쿠키(access_token)로 관리되나, auth-proxy.controller.ts:184 의 로그아웃 핸들러에서 refresh_token 쿠키만 clearCookie 로 삭제하고 access_token 쿠키는 삭제하지 않음. user-auth의 auth.controller.ts:230 에서는 두 쿠키를 모두 삭제하지만, API Gateway 프록시 구조상 user-auth가 설정한 Set-Cookie 헤더가 sanitizeAndForwardCookies 를 통해 전달되지 않을 수 있음(로그아웃 응답에서 sanitizeAndForwardCookies 미호출). 결과적으로 로그아웃 후에도 15분간 유효한 access_token 쿠키가 브라우저에 남아 인증된 요청이 가능
- **위치:** backend/services/api-gateway/src/proxy/auth-proxy.controller.ts:184
- **영향:** 로그아웃 후 최대 15분간(엑세스 토큰 만료 시간) 세션 유지. 공유 컴퓨터에서 다음 사용자가 이전 사용자의 세션으로 API 호출 가능
- **권장:** 로그아웃 핸들러에서 res.clearCookie('access_token', { path: '/' }) 추가 또는 sanitizeAndForwardCookies(result.headers?.['set-cookie'], res) 호출
- **심각도:** High

B. 입력 검증 — 2건

[VAL-M-02] 주문 수량 프론트엔드 소수점 자릿수 미제한 (Medium, 미수정)

- **현상:** OrderForm.tsx 에서 수량 직접 입력 시 소수점 20자리 이상 입력 가능. 비율 버튼 사용 시 .toFixed(8) 로 포맷되지만 직접 입력에는 제한 없음
- **위치:** frontend/src/components/trading/OrderForm.tsx:304
- **영향:** 극단적 소수점 값으로 인한 백엔드 Decimal 연산 비용 증가
- **권장:** 입력 필드에서 소수점 8자리 제한 또는 onBlur 시 .toFixed(8) 적용
- **심각도:** Medium

[VAL-L-01] auth-proxy 컨트롤러 — 인증 관련 body 타입 unknown으로 전달 (Low, 미수정)

- **현상:** auth-proxy.controller.ts 의 register , login , sendSmsCode 등 다수 엔드포인트에서 @Body() body: unknown 으로 body를 수신하여 user-auth 서비스로 그대로 전달. API Gateway 레벨에서 DTO 검증 없이 다운스트림 서비스에 의존
- **위치:** backend/services/api-gateway/src/proxy/auth-proxy.controller.ts:64,92,111,215,231,247,265,281
- **영향:** 잘못된 요청이 다운스트림 서비스까지 전달되어 불필요한 부하 발생
- **권장:** 최소한 register , login 엔드포인트에 Gateway 레벨 DTO 적용 검토
- **심각도:** Low

C. 에러 처리/정보 노출 — 3건

[ERR-M-01] 주문 프록시 — 거래 알림 실패 시 내부 에러 메시지 로깅 (Medium, 미수정)

- 현상: order-proxy.controller.ts:62 에서 sendTradeNotification 실패 시 e.message 를 Logger.warn으로 출력. 프로덕션 환경에서 내부 서비스 URL, 인증 토큰 관련 에러가 로그에 노출될 가능성
- 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:62
- 영향: 로그 수집 시스템에서 민감 정보 노출 가능
- 권장: 에러 메시지를 일반화하거나 e.message 대신 에러 코드만 기록
- 심각도: Medium

[ERR-M-02] any 타입 사용에 의한 타입 안전성 결여 (Medium, 미수정)

- 현상: order-proxy.controller.ts:164-176 에서 as Record<string, any>, (t: any), (u: any) 등 any 타입 사용. portfolio-proxy.controller.ts 에서 (req as Record<string, any>).user?.id 패턴이 다수 반복(42, 58, 74, 90, 105, 119, 134, 155, 250, 273, 309, 366, 385, 404 행). ai-proxy.controller.ts:48 에서도 (req as Record<string, any>).user?.id 패턴 사용
- 위치: backend/services/api-gateway/src/proxy/order-proxy.controller.ts:164-176 , backend/services/api-gateway/src/proxy/portfolio-proxy.controller.ts (14개소), backend/services/api-gateway/src/proxy/ai-proxy.controller.ts:48
- 영향: 예상치 못한 데이터 구조 변경 시 런타임 크래시, 타입 가드 부재로 잘못된 속성 접근 가능
- 권장: @CurrentUser('id') userId: string 데코레이터를 모든 프록시 컨트롤러에 일관 적용 (order-proxy에서는 이미 사용 중)
- 심각도: Medium

[ERR-L-01] 프론트엔드 catch 블록 — 에러 무시 패턴 반복 (Low, 미수정)

- 현상: portfolio/page.tsx:99-101, 113-115 에서 catch { // Error handled by query client } 패턴으로 에러를 무시. 에러 객체를 참조하지 않아 디버깅 시 원인 추적 어려움
- 위치: frontend/src/app/(main)/portfolio/page.tsx:99, 113
- 영향: 네트워크/서버 에러 원인 파악 지연
- 권장: 최소한 catch (e) { console.debug(e); } 또는 에러 추적 서비스 연동
- 심각도: Low

D. XSS/CSP 방어 — 1건

[CSP-M-01] CSP script-src — unsafe-inline + strict-dynamic 공존 (Medium, 미수정)

- 현상: next.config.ts:9 에서 프로덕션 CSP script-src 가 'self' 'unsafe-inline' 'strict-dynamic' 으로 설정. CSP 3.0 지원 브라우저에서 'unsafe-inline' 은 무시되지만, CSP 2.0만 지원하는 브라우저에서 인라인 스크립트 실행 허용. SEC-C-01 수정으로 토큰이 쿠키로 전환되어 XSS 시 직접적인 토큰 탈취는 방지되나, 여전히 인라인 스크립트로 세션 조작 가능
- 위치: frontend/next.config.ts:9
- 영향: CSP 2.0 브라우저에서 XSS 방어력 약화
- 권장: nonce 기반 CSP로 전환하여 'unsafe-inline' 완전 제거
- 심각도: Medium

E. 인가/권한 검증 — 3건

[AUTH-M-01] 호가창 엔드포인트 — 인증 불필요 노출 (Medium, 미수정)

- **현상:** GET /api/orders/book/:symbol 에 인증 가드가 없음. 호가창 데이터에 사용자들의 주문 가격/수량이 포함
- **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:208-218
- **영향:** 비인증 스크래퍼가 호가 데이터를 자동 수집하여 시장 미시구조 분석/조작에 활용
- **권장:** 공개 API 여부 명시적 결정 후 비공개 시 JwtAuthGuard 추가, 공개 결정 시 엔드포인트별 Rate Limit 적용
- **심각도:** Medium

[AUTH-L-01] 공개 포트폴리오 API — 보유 자산 절대 수량 노출 (Low, 미수정)

- **현상:** /api/portfolio/public/:userId 를 통해 다른 사용자의 보유 심볼, 수량, 평균가, 수익률을 정확히 조회 가능
- **위치:** backend/services/api-gateway/src/proxy/portfolio-proxy.controller.ts:222-235
- **영향:** 특정 사용자의 정확한 포지션 크기가 노출되어 의도적 반대매매 가능
- **권장:** 보유 비율(%)만 공개하고 절대 수량은 마스킹
- **심각도:** Low

[MISC-L-01] 공지사항 생성/수정 — Gateway 레벨 AdminRolesGuard 미적용 (Low, 미수정)

- **현상:** AnnouncementProxyController 의 컨트롤러 레벨에 @UseGuards(JwtAuthGuard) 만 적용. POST /api/announcements (생성), PUT /api/announcements/:id (수정), DELETE /api/announcements/:id (삭제), POST /api/announcements/:id/pin (고정) 등 관리자 전용 엔드포인트에 AdminRolesGuard 가 없음. 감사 로그는 추가되었으나 Gateway 레벨 권한 차단은 미적용
- **위치:** backend/services/api-gateway/src/proxy/announcement-proxy.controller.ts:30-31,125,156,193,217
- **영향:** 관리자가 아닌 인증 사용자가 공지사항 생성/수정/삭제 API를 호출하면 user-auth까지 요청이 전달된 후 거부됨 (불필요한 서비스 부하)
- **권장:** 생성/수정/삭제/고정 토큰 엔드포인트에 AdminRolesGuard 추가
- **심각도:** Low

F. 서비스 간 통신 — 1건

[SVC-M-01] 서비스 간 HTTP 통신 — HTTPS 미적용 (Medium, 미수정)

- **현상:** ProxyService.initClients() 에서 모든 내부 서비스 URL이 http://\${host}:\${port} 형태로 생성. Docker 네트워크 또는 K8s 클러스터 내부에서도 서비스 간 통신이 평문 HTTP로 수행됨
- **위치:** backend/services/api-gateway/src/proxy/proxy.service.ts:70-77
- **영향:** 같은 네트워크에 있는 공격자가 서비스 간 트래픽을 가로채 내부 시크릿 및 사용자 데이터 탈취 가능
- **권장:** 프로덕션에서 서비스 메시(Istio/Linkerd) mTLS 적용 또는 서비스 간 HTTPS 사용 검토
- **심각도:** Medium

G. 감사 로깅 — 1건

[AUD-M-01] 비밀번호 재설정 — 성공/실패 이벤트 로깅 불충분 (Medium, 미수정)

- **현상:** AuthService.resetPassword() 에서 비밀번호 재설정 성공 시 logger.log 만 기록. 실패(잘못된 sessionId, 미인증 세션 등)의 경우 UnauthorizedException 만 발생하고 별도 실패 로그가 없음
- **위치:** backend/services/user-auth/src/application/services/auth.service.ts:668-705
- **영향:** 비밀번호 재설정 악용 시도 패턴 감지 불가
- **권장:** 비밀번호 재설정 성공/실패 시 구조화된 감사 이벤트 기록 (userId, sessionId, IP, timestamp, result)
- **심각도:** Medium

H. 기타 — 2건

[FE-M-01] RichEditor 이미지 업로드 — 서버 실패 시 Base64 폴백 유지 (Medium, 미수정)

- **현상:** RichEditor.tsx:144-147 에서 서버 업로드 실패 시 `editor.chain().focus().setImage({ src: dataUrl }).run()` 으로 Base64 data URL 폴백. 대용량 Base64 데이터가 게시글 HTML에 포함되어 DB에 저장됨
- **위치:** frontend/src/components/ui/RichEditor.tsx:144-147
- **영향:** 서버 불안정 시 DB에 대용량 Base64 저장, 게시글 조회 성능 저하
- **권장:** 서버 업로드 실패 시 사용자 에러 알림 후 이미지 삽입 차단
- **심각도:** Medium

[FE-M-02] 주문 폼 — displayCurrentPrice 기반 최대 수량 계산 편차 (Medium, 미수정)

- **현상:** OrderForm.tsx:321 에서 매수 100% 비율 클릭 시 `maxQty = portfolio.cashBalance / displayCurrentPrice` 로 계산. `displayCurrentPrice` 는 환율 변환이 적용된 표시 가격이므로 반올림 오차로 잔액 부족 에러 발생 가능
- **위치:** frontend/src/components/trading/OrderForm.tsx:320-323
- **영향:** 100% 매수 시 환율 변환 오차가 1% 이상일 경우 주문 실패
- **권장:** 최대 수량 계산을 백엔드 USD 가격 기준으로 수행
- **심각도:** Medium

종합 평가

22차 시스템 감사에서 총 14건의 이슈를 발견하였습니다. 21차 대비 7건이 수정되었고(SEC-C-01, SEC-H-01, AUTH-H-01, AUD-H-01, VAL-M-01, HDR-M-01, CSP-M-02), 12건이 미수정 상태이며, 수정 과정에서 1건의 신규 이슈가 발견되었습니다.

수정 현황 (7건 수정)

- **SEC-C-01** (Critical → 수정): JWT 액세스 토큰 httpOnly 쿠키 전환 — sessionStorage에서 완전히 제거, 브라우저 쿠키 자동 전송 방식으로 전환
- **SEC-H-01** (High → 수정): CORS allowedHeaders에서 내부 서비스 헤더(x-user-id, x-internal-token) 제거
- **AUTH-H-01** (High → 수정): AI 엔드포인트에 JwtAuthGuard + 분당 10회 Rate Limit 적용
- **AUD-H-01** (High → 수정): 관리자 전체 민감 작업에 [ADMIN_AUDIT] 구조화 감사 로그 추가
- **VAL-M-01** (Medium → 수정): PlaceOrderDto에 @Matches + @MaxLength 검증 추가
- **HDR-M-01** (Medium → 수정): Next.js + API Gateway 양쪽에 Permissions-Policy 헤더 적용
- **CSP-M-02** (Medium → 수정): 프로덕션 빌드에서 localhost 와일드카드 제거 (환경 분리)

미수정 12건

- VAL-M-02, ERR-M-01, ERR-M-02, ERR-L-01, CSP-M-01, AUTH-M-01, AUTH-L-01, SVC-M-01, AUD-M-01, FE-M-01, FE-M-02, MISC-L-01, VAL-L-01

22차 신규 발견 (수정 과정 도입)

1. **API Gateway 로그아웃 시 access_token 쿠키 미삭제** (SEC-H-02, High) — SEC-C-01 수정으로 도입된 회귀 이슈. 로그아웃 후 최대 15분간 세션 유지

핵심 개선 사항

21차에서 Critical로 판정되었던 **SEC-C-01 (JWT sessionStorage 저장)** 이 수정되어 22차에서는 **Critical 이슈가 0건**으로 감소하였습니다. 21차의 High 이슈 3건 중 모두 수정되었으나, 수정 과정에서 도입된 SEC-H-02가 새로운 High 이슈로 추가되었습니다.

우선 수정 권장 순서

- 1. SEC-H-02 (High) — 로그아웃 시 access_token 쿠키 삭제 (1줄 추가로 해결 가능)
- 2. CSP-M-01 (Medium) — nonce 기반 CSP 전환
- 3. ERR-M-02 (Medium) — @CurrentUser 데코레이터 일관 적용으로 any 타입 제거
- 4. SVC-M-01 (Medium) — 프로덕션 서비스 메시 mTLS 적용 검토
- 5. AUD-M-01 (Medium) — 비밀번호 재설정 감사 이벤트 강화

본 보고서는 자동 생성된 감사 결과이며, 수정 사항은 포함되지 않습니다.